



中国互联网安全大会



360互联网安全中心

ISC
2015

数据驱动安全

2015 中国互联网安全大会
China Internet Security Conference

发现网络空间里的
「暗物质」情报

关于我

- 余弦，ZoomEye船长



分享内容

- 透视网络空间
- 我们的情报体系概览
- 枚举暗物质与对应的情报经验



透视网络空间

透视网络空间

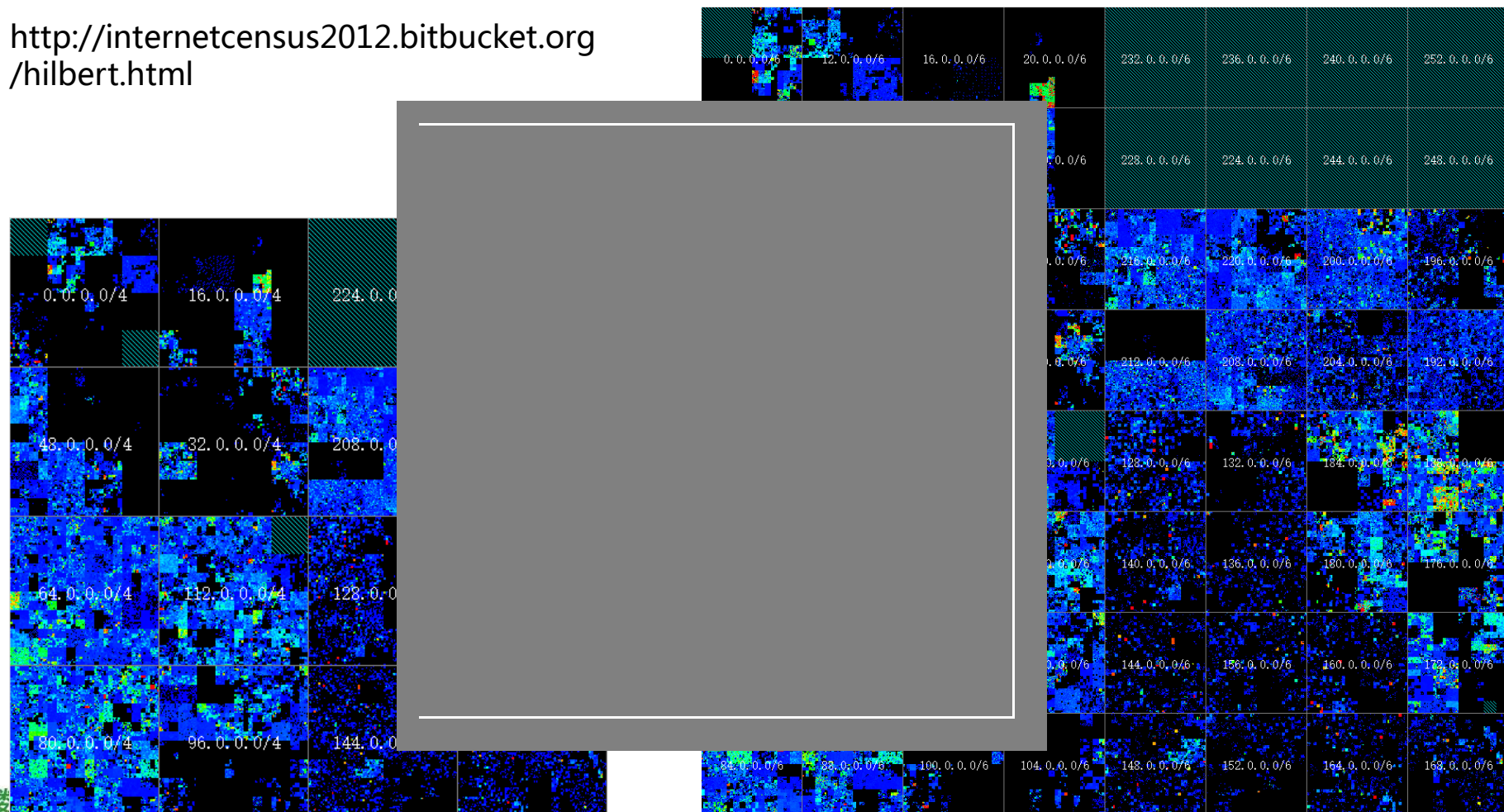
这张「航海图」很关键



透视网络空间

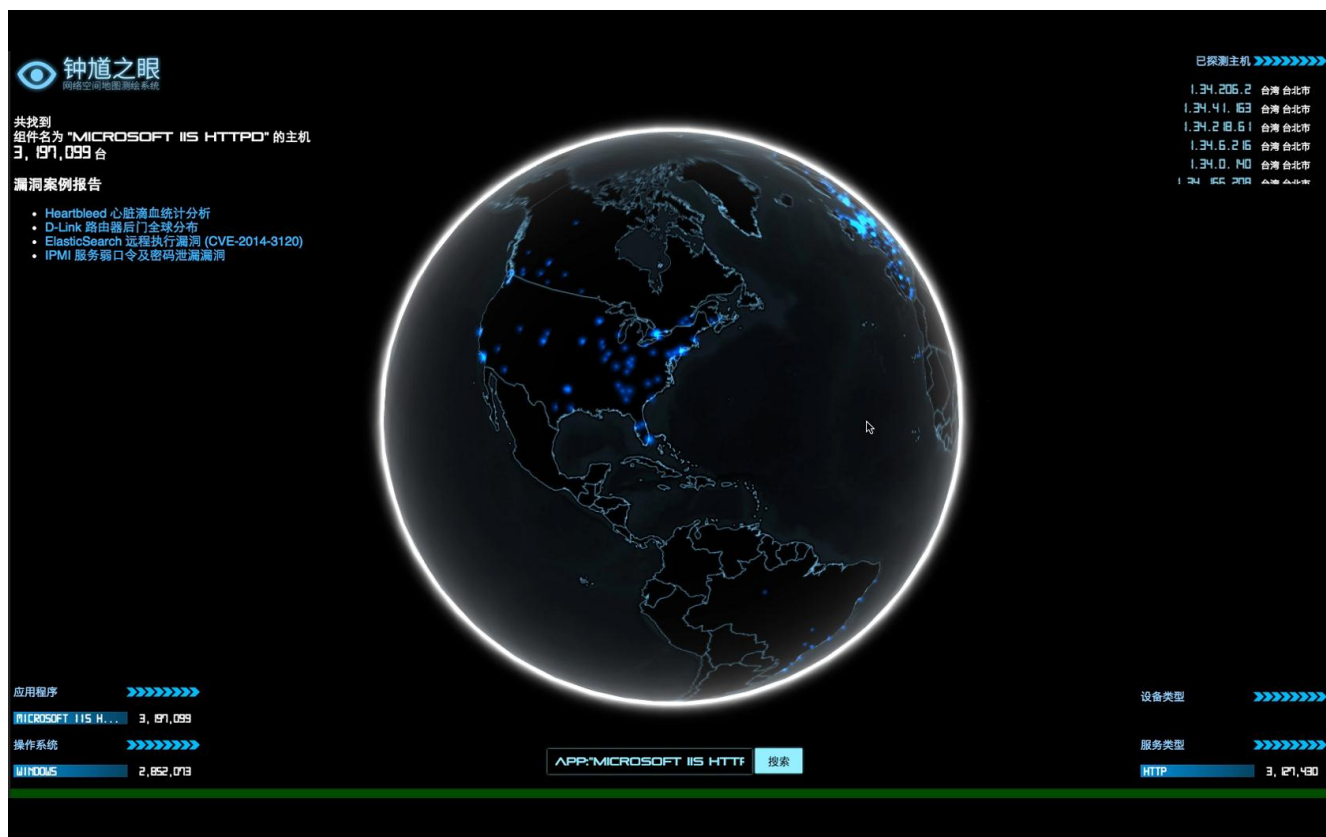
希尔伯特曲线

<http://internetcensus2012.bitbucket.org/hilbert.html>



组件识别

- 组件是网络空间里的最小识别单元
 - IP -> 端口 -> 服务 -> 组件



透视网络空间

真正的透视需要做到

- 组件识别
- 组件之间的层级关系，比如Web组件的8+1层结构
- 组件高一维度的设备信息
- 设备之间的网络层级关系
- 设备高一维度的使用方信息（人）
- 人高一维度的社交信息
- 物理位置信息
- 漏洞信息 - 开启上帝视角
- ...



透视网络空间

小结

- IPv4空间里有大量地址未被探测到（历史）
 - 这个比例可能是2/3
- IPv4空间里当前能很好探知主流组件的IP总量可能不超过2亿
- 透视网络空间需要以组件识别为出发点
- 透视网络空间是一件极其复杂的工程问题
- 网络空间里那些我们还没法认识的东西我们这里定义为「暗物质」

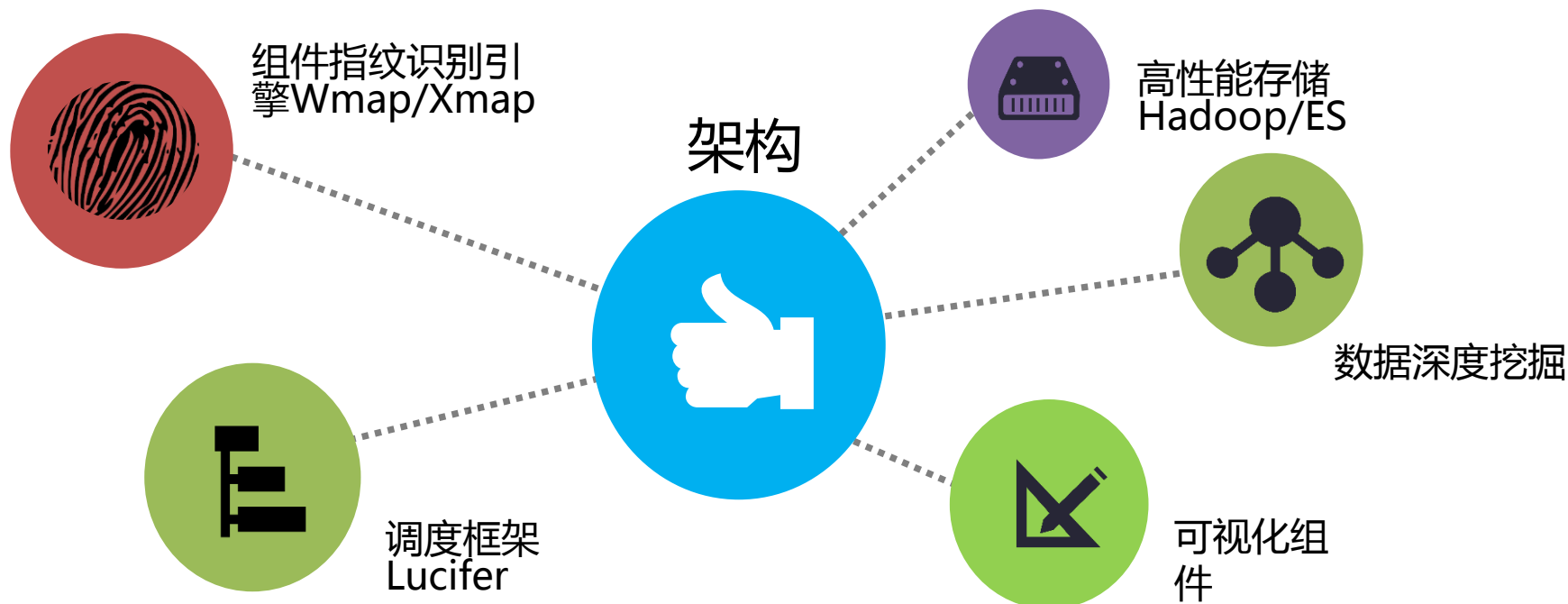
透视网络空间要求我们逐步消除这些「暗物质」！



我们的情报体系概览

我们的情报体系概览

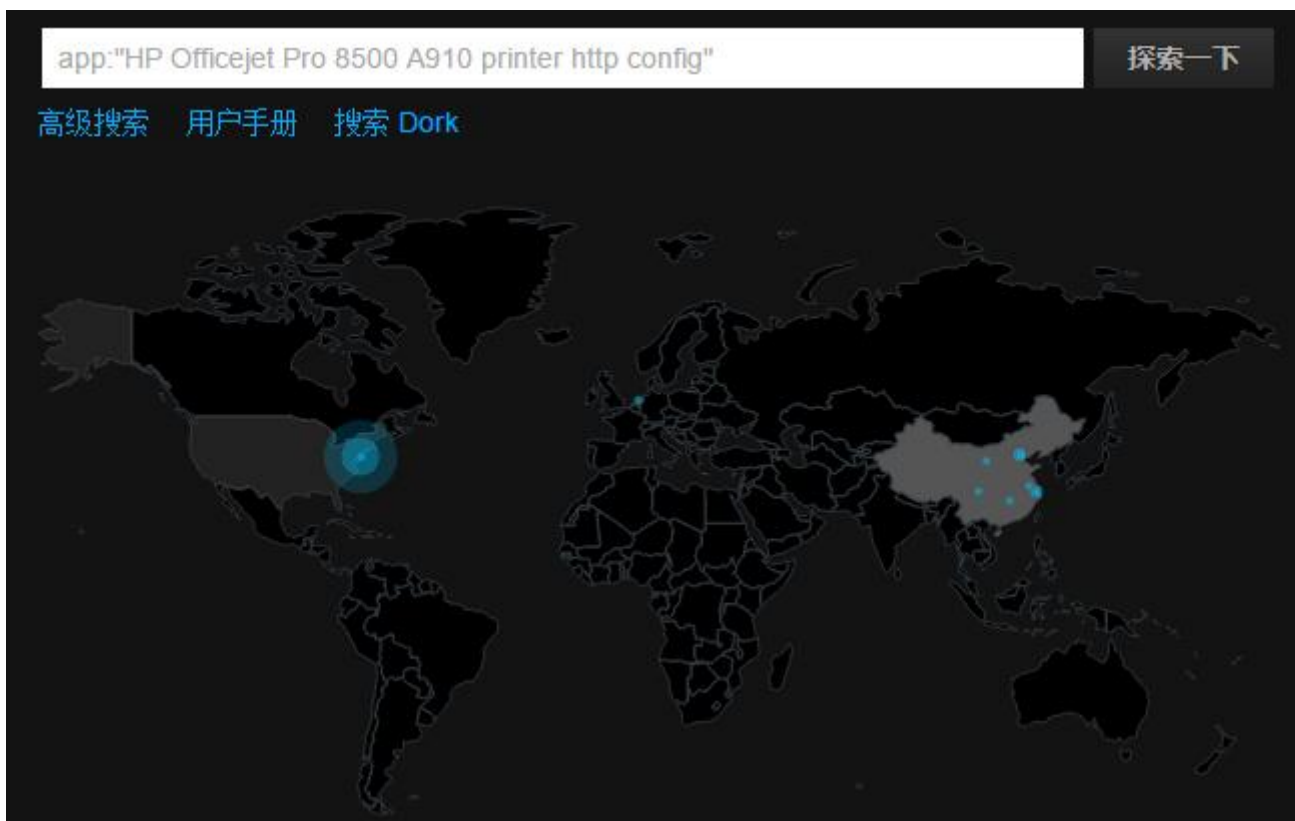
ZoomEye架构



我们的情报体系概览

Dork体系

- 每次搜索都将诞生一个Dork



我们的情报体系概览

Dork体系

- <http://www.zoomeye.org/search/dork>

推荐搜索 Dork

Explore Everything, Exploit Everything!

推荐搜索 Dork

标签: [server](#) [bbs](#) [port](#) [database](#) [camera](#) [city](#) [weak](#) [password](#) [waf](#) [skydrive](#) [http](#) [server](#) [gateway](#) [ftp](#) [router](#) [firewall](#) [ics](#) [school](#) [storage](#) [email](#) [Console](#) [ssh](#) [vnc](#) [os](#) [java](#) [monitor](#) [media](#) [VoIP](#) [switch](#) [oa](#) [modem](#) [erp](#) [project](#) [manage](#) [smart](#) [home](#) [vpn](#) [wap](#) [file](#) [system](#) [home](#) [office](#) [printer](#) [dvr](#) [ad](#) [ap](#) [vdi](#) [proxy](#) [ads](#) [protocol](#) [webcam](#) [ops](#) [cms](#) [wireless](#) [controller](#) [driver](#) [admin](#) [hosting](#) [control](#) [bridge](#) [deploy](#) [baidu](#) [mail](#) [honeypot](#) [DLP](#) [security](#) [PLC](#) [nas](#) [editor](#) [framework](#) [remote](#) [control](#) [web](#) [framework](#) [application](#) [server](#) [front-end](#) [framework](#) [telneted](#) [web](#) [dns](#) [SMTP](#) [server](#) [system](#) [power](#) [web](#) [httpd](#)

 探索一下

Dork	描述	推荐时间
service:"java-rmi"	Java远程方法调用服务	2015-09-11
P3P: CP='CURa ADMa DEVa PSAo PSDo OUR BUS UNI PUR INT DEM STA PRE COM NAV OTC NOI DSP COR' Server: lighttpd	ShareCenter是D-Link旗下的NAS设备。	2015-08-30
app:"HyNetOS"	全性能操作系统, 包括一个含实时以太网的通信协议栈集合、一个文件系统和存储器管理	2015-08-20
app:"oecms"	OECMS是一款php建站系统	2015-08-19
service:"jabber"	Jabber是XMPP(Extensible Messaging and Presence Protocol)的曾用名。	2015-08-17
service:"minecraft"	Minecraft是一款沙盒游戏。	2015-08-17

我们的情报体系概览

有意义的漏洞情报

- <http://www.sebug.net/>

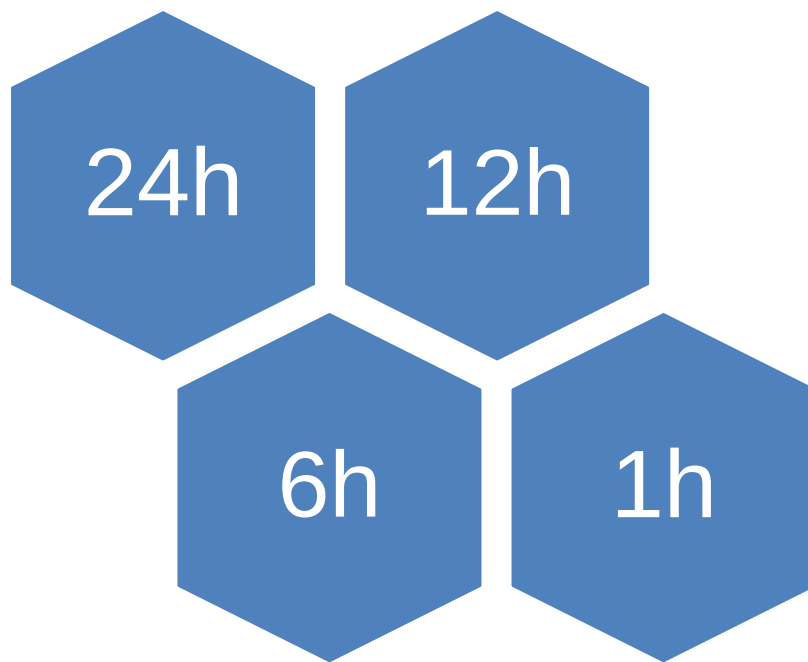
	Root	2015-09-23 16:27:59	分成	Schneider Electric Modicon M340 PLC Station P34模块Web Servers安全漏...	漏洞详情	 0.5KB
	00r00	2015-09-23 16:27:15	兑换	MagnetoSoft ICMP 4.0.0.18 - ActiveX AddDestinationEntry BOF	PoC/Exp	 0KB
	Root	2015-09-23 16:27:15	分成	MagnetoSoft ICMP 4.0.0.18 - ActiveX AddDestinationEntry BOF	PoC/Exp	 0KB
	匿名者	2015-09-23 16:16:53	兑换	Schneider Electric Modicon M340 PLC Station P34模块Web Servers安全漏...	漏洞详情	 -0.5KB
	Root	2015-09-23 16:16:53	分成	Schneider Electric Modicon M340 PLC Station P34模块Web Servers安全漏...	漏洞详情	 0.5KB
	evilcos	2015-09-23 16:03:04	兑换	Schneider Electric Modicon M340 PLC Station P34模块Web Servers安全漏...	漏洞详情	 -0.5KB
	Root	2015-09-23 16:03:04	分成	Schneider Electric Modicon M340 PLC Station P34模块Web Servers安全漏...	漏洞详情	 0.5KB
	evilcos	2015-09-23 16:02:32	兑换	施耐德(Schneider) Modicon PLC 数据包重放远程控制(Start/Stop Command)	PoC/Exp	 -4KB
	Kimon	2015-09-23 16:02:32	分成	施耐德(Schneider) Modicon PLC 数据包重放远程控制(Start/Stop Command)	PoC/Exp	 4KB

[« 上一页](#)[1 ...](#)[11](#)[12](#)[13](#)[14](#)[15](#)[16](#)[17](#)[18](#)[19](#)[20](#)[21](#)[22](#)[23](#)[24](#)[25](#)[26](#)[27](#)[28](#)[29](#)[30](#)[31](#)[...](#)[252](#)[下一页 »](#)

我们的情报体系概览

小结

- 透视网络空间后结合有意义的漏洞情报 -> 及时预警
 - 跟进每个有意义漏洞的生命周期
 - 黄金应急时间





枚举暗物质与对应的情报经验

枚举暗物质与对应的情报经验

之物联网屠宰场

枚举暗物质与对应的情报经验

摄像头威胁

ZoomEy

搜索: dcs-1130-httpd 探索一下

搜索结果 全球视角

搜索类型

公网设备

Web

http://223.190.8.113/

223.190.8.113

Se

AdminPasswd_s: "buddy"

Unk

Usage: rtpd.cgi?action=[start|stop|restart|status|get|set]&...

http 5785

Country

UNITED STATES 19087 ^

SAN FRANCISCO 440

exploit_dcs_1130.py

exploit_iqnvision.py

exploit_pvc2300.py

exploit_trendnet.py

exploit_wvc80n.py

modify_image.py

US-13-Heffner-Exploiting-Network-Surveillance-Cameras-Like-A-Hollywood-Hacker-Slides.pdf

US-13-Heffner-Exploiting-Network-Surveillance-Cameras-Like-A-Hollywood-Hacker-WP.pdf

Content-Length: 2378

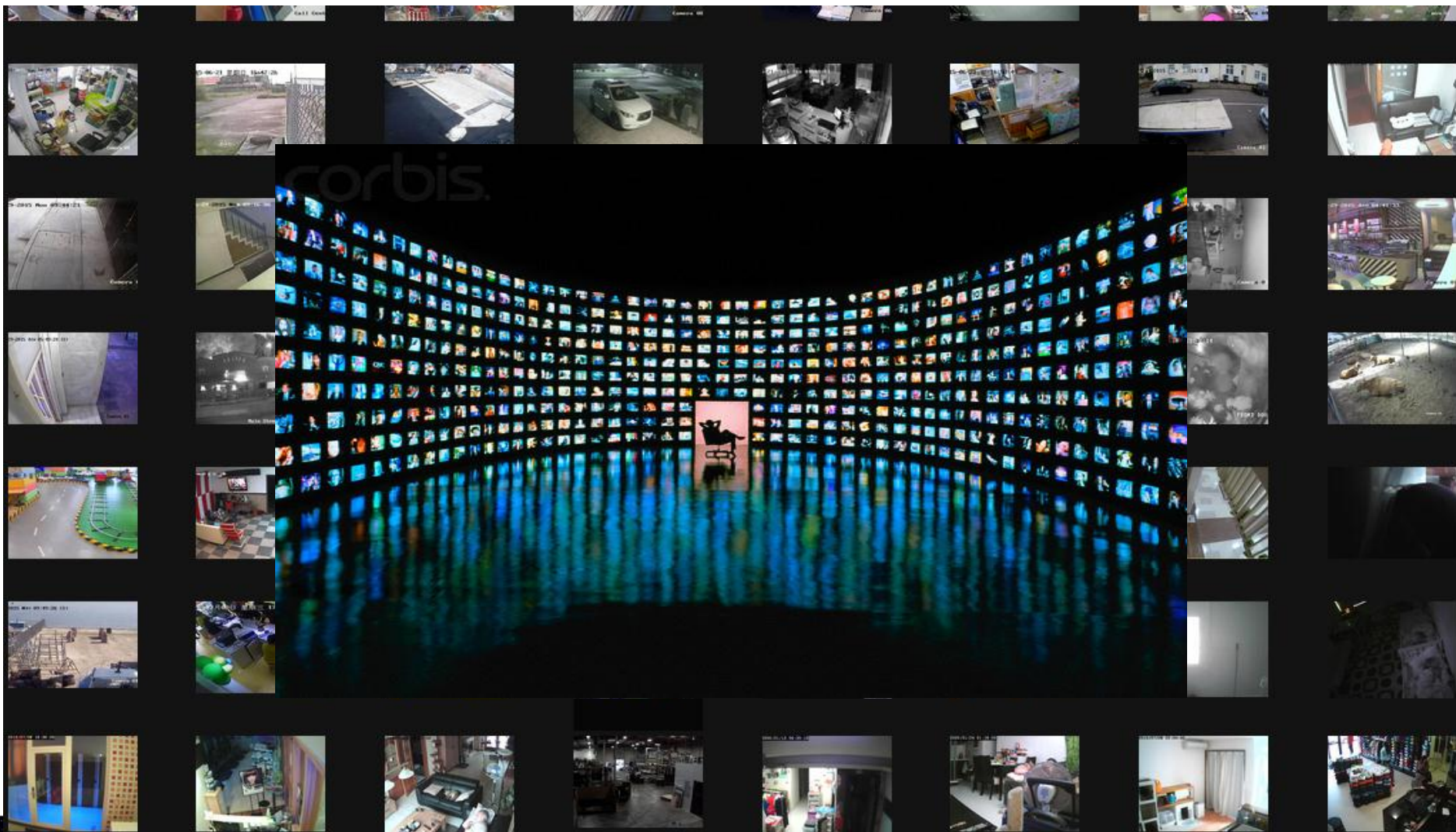
Date: Thu, 27 May 2010 22:05:59 GMT

Server: dcs-1130-httpd

<html>

枚举暗物质与对应的情报经验

摄像头威胁



枚举暗物质与对应的情报经验

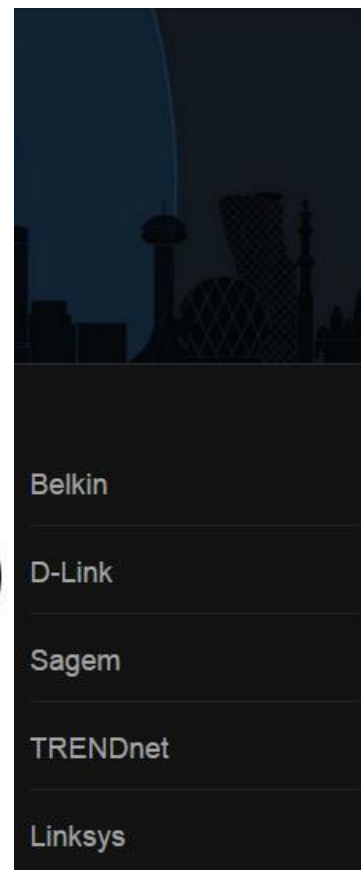
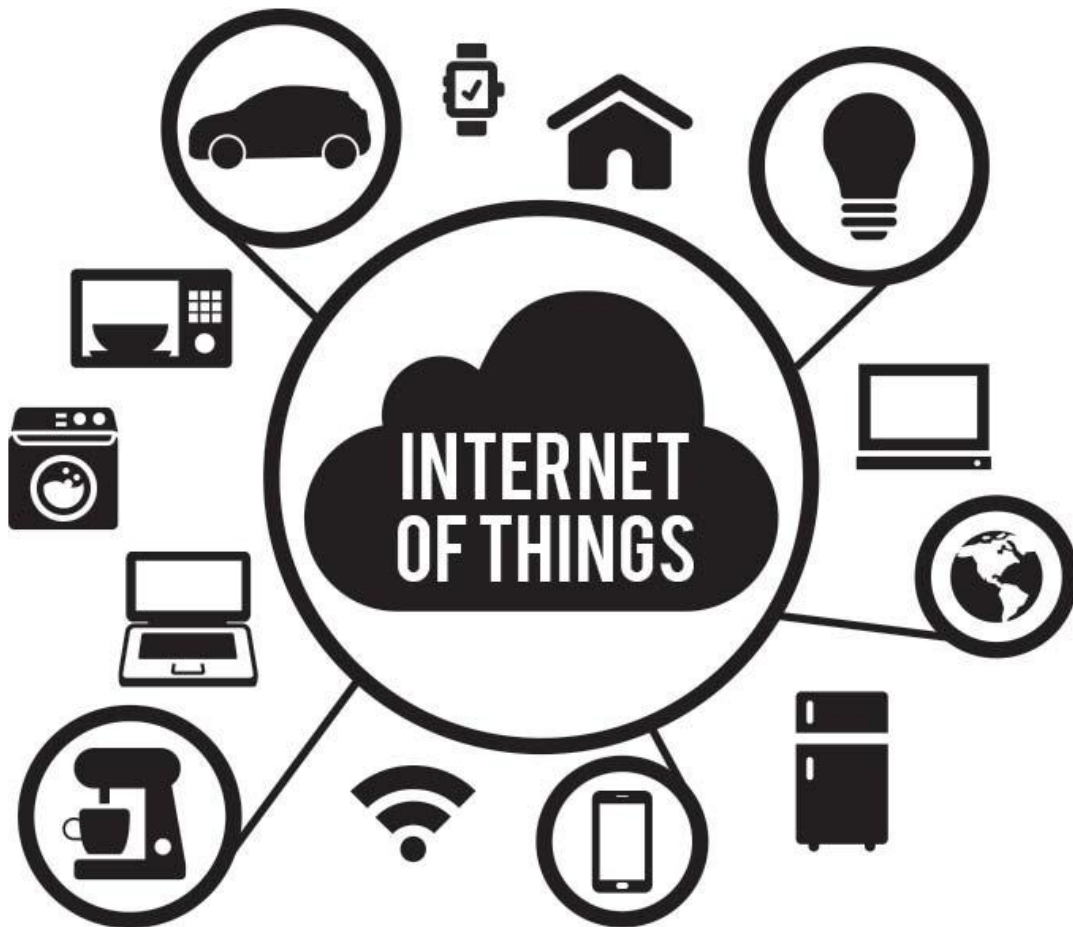
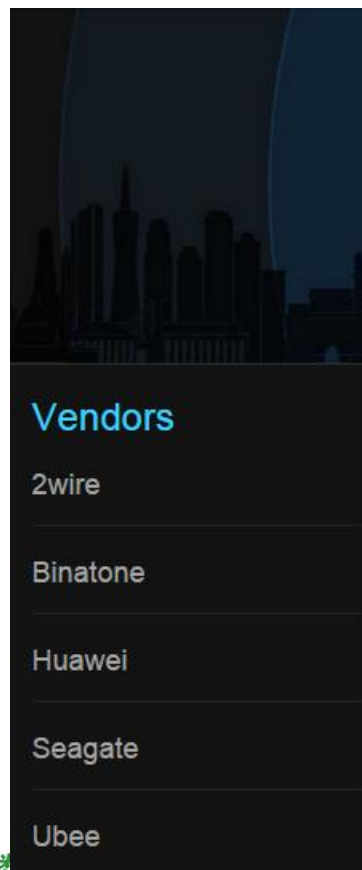
摄像头威胁

- 思考个问题：你有全球某摄像头控制权，你能如何？
 - 如果没法提炼所需目标情报，这么多控制下来有何用？
 - 当普通嵌入式系统用？...别跑题！
 - 思路？
 - 批量取摄像头静态/动态图片下来，比较简单
 - 图片里的文字识别，挺有挑战
 - 图片里的人脸识别，非常有挑战
 - 当这些挑战不再是挑战时，这类威胁就非常有意思了:)

枚举暗物质与对应的情报经验

路由器威胁

- <http://www.zoomeye.org/project/router>



枚举暗物质与对应的情报经验

路由器威胁

- D-Link后门

There were about 6

.org/search?q=app:"D-Link%20DIR-100%20http

app:"D-Link DIR-100 http config"

© 七月 24, 2015

213. [REDACTED] 237

D-Link DIR-100 http config

broadband router

Czechia Opava

© 七月 24, 2015

195. [REDACTED] 74

D-Link DIR-100 http config

broadband router

Slovakia Bratislava

© 七月 24, 2015

Protocol	Source IP	Source Port	Dest IP	Dest Port	Age Time
UDP	192.168.1.100	33436	8.8.8.8	53	98
TCP	192.168.1.100	51503	74.125.136.95	443	471
TCP	192.168.1.100	56325	74.125.136.95	443	472
TCP	192.168.1.100	41265	173.194.65.188	5228	3301
TCP	192.168.1.100	38989	74.125.136.108	993	3012
UDP	192.168.1.100	59381	8.8.8.8	53	4
UDP	192.168.1.100	52941	8.8.8.8	53	67

枚举暗物质与对应的情报经验

路由器威胁

- D-Link后门不过瘾？来看看磊科(NetCore)的
 - 2014/8/25，趋势科技研究员Tim Yeh发文描述了磊科疑似后门的igdmpd程序，全球有200多万台磊科路由受影响
 - 2014/10/3，Tim Yeh再次发文称磊科官方发布了新版固件，但新固件中只是默认关闭了「后门」程序，而并未将其删除。ShadowServer的统计受影响路由器仍有100多万台
 - 2014/12/28，国内研究员h4ckmp发文详细分析了该「后门」
 - 2014/12/31，ZoomEye Team进行了细节验证并发文
 - 2015/9，ZoomEye Team的探测发现UDP 53413端口的IP总数约为140万，其中110万左右是存在后门的磊科路由器，占比近80%
 - 其中95%在中国:(

枚举暗物质与对应的情报经验

路由器威胁

- 磊科的igdmpd这个「后门」威力如何？
 - 以root权限执行系统命令
 - 任意文件上传、下载
 - 某些常用路由配置功能
- 在我们取证分析中发现这些路由器早被虐遍了
 - 绝大多数木马为MIPS平台上的ELF可执行程序，大都采用了随机文件名
 - 其中少数为.sh程序，多用于进一步下载相关ELF木马
 - 在3次扫描中，共抓取到近1400个木马样本，其中不同md5值的一共有583个
 - ...

枚举暗物质与对应的情报经验

路由器威胁

- 磊科「后门」木马的特点：
 - 基于弱口令（telnet、ssh等）的蠕虫式传播
 - 支持多个嵌入式CPU架构（ARM、MIPS、PowerPC）
 - 变种多样、变化频繁
 - 大多利用嵌入式设备进行扫描、DDoS等，少数的呢？

枚举暗物质与对应的情报经验

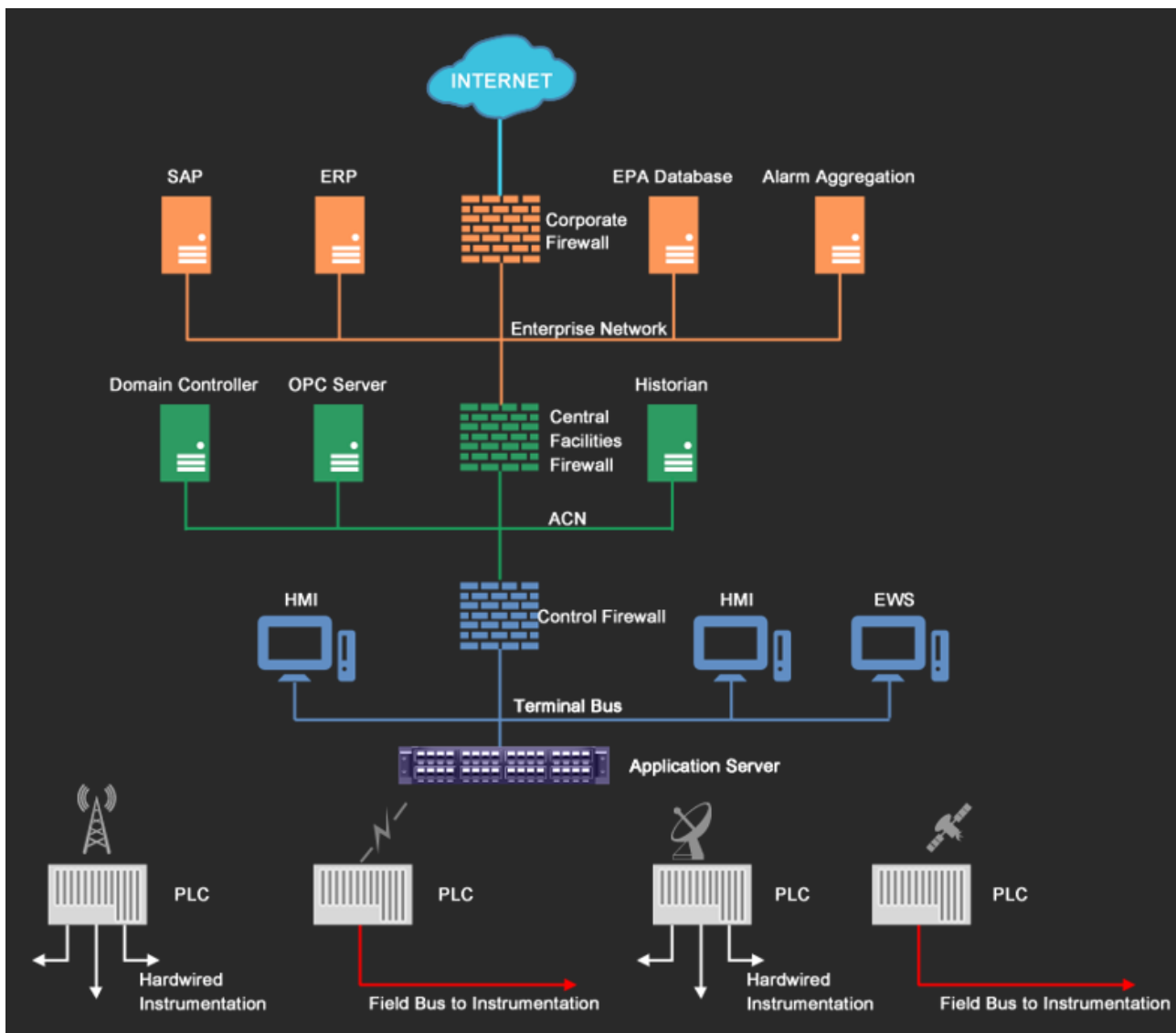
路由器威胁

- 思考个问题：你有全球某路由器控制权，你能如何？
 - 黑产守则一：流量即钱？
 - DDoS/CC资源？
 - 跳板 - 密网？
 - 拿用户各类隐私？
 - 你思考的问题，地下黑客不仅早思考了还行动了...

枚举暗物质与对应的情报经验

工控威胁

- 最重要的脆弱系统



枚举暗物质与对应的情报经验

工控威胁

Anybus MODBUS GATEWAY

START NETWORK MODBUS STATUS ADMIN ABOUT

Serial Settings (Modbus RTU / ASCII)

Status

Transparent Queries

← → ↻ 217.100:81/cgi-bin/read.cgi?page=../../etc/passwd

```
root:RM4.EMXm4X0.g:0:0:root:/:/bin/sh shutdown::6:0:shutdown:/:bin:/bin/reboot
```

CRC Errors	112
Buffer Overruns	0
Frame Errors	0
Exception Responses	131

clear

IP Authentication ☐

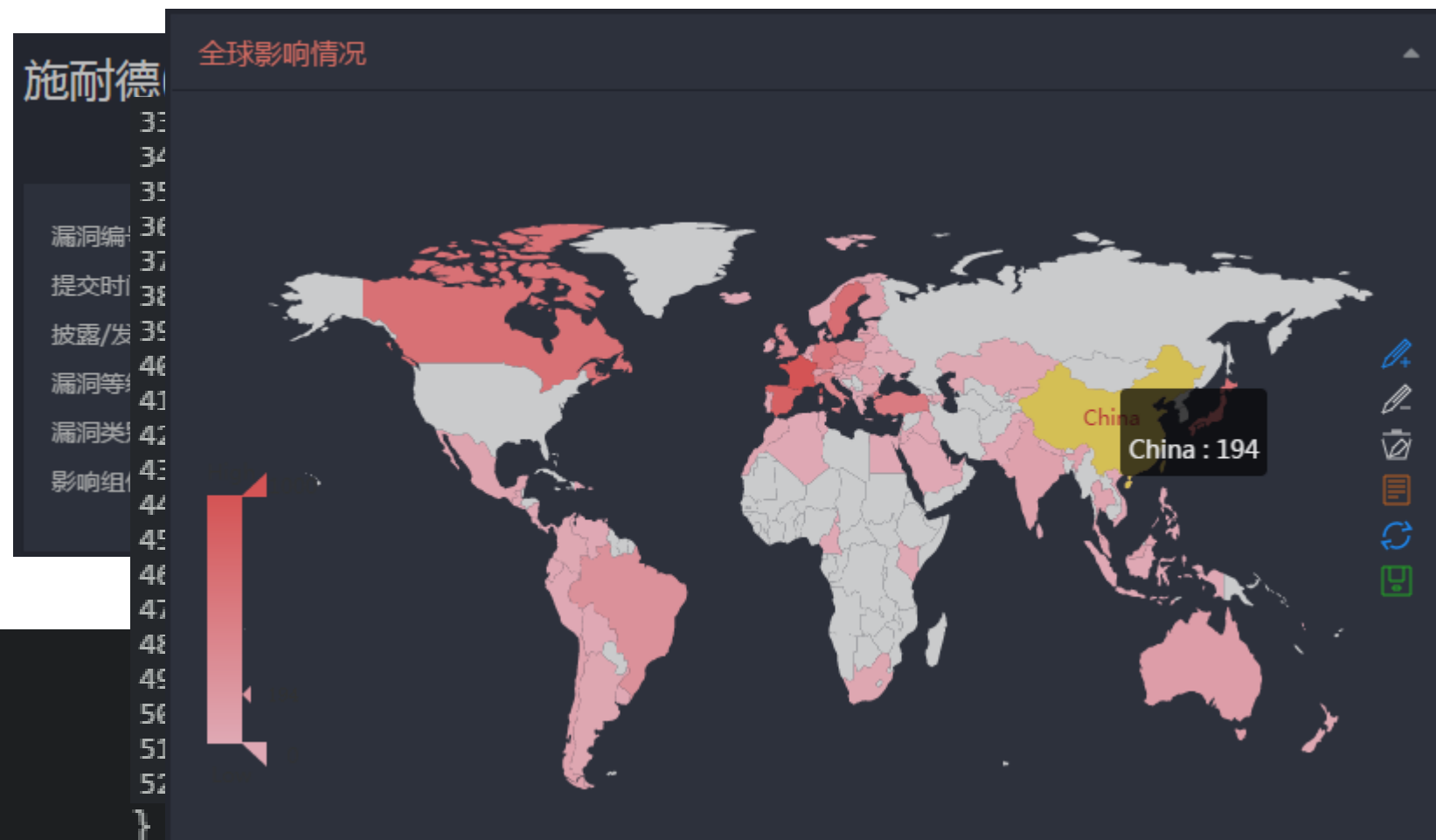
Mask: . . .

save settings

枚举暗物质与对应的情报经验

工控威胁

- 危害还能更直接些吗？



枚举暗物质与对应的情报经验

工控威胁

This figure displays a complex industrial monitoring system interface, likely for a water treatment plant, featuring multiple video feeds and a detailed sidebar menu.

Top Bar: The top of the interface includes a navigation bar with the following elements from left to right: "Generic", "Generic", "Generic", and "ModbusGW".

Main Content Area: The main area is divided into two identical horizontal sections, each displaying two video feeds from Hikvision DS-7804HW-E1/M cameras.

- Section 1 (Top):** The left sidebar lists camera locations: "站" (Station), "站外部" (Station External), "站内部" (Station Internal), "NA", and "NA". The video feeds show an external view of a building (labeled "站外") and an internal view of industrial equipment (labeled "站内"). The timestamp for both is "2014年11月16日 星期日 16:08:31".
- Section 2 (Bottom):** The left sidebar lists camera locations: "站" (Station), "站外部" (Station External), "站内部" (Station Internal), "NA", and "NA". The video feeds show an external view of a building (labeled "站外") and an internal view of industrial equipment (labeled "站内"). The timestamp for both is "2014年10月20日 星期一 14:52:33".

Left Sidebar: A vertical sidebar on the far left contains the following elements:

- ZoomEye** logo.
- SIEMENS** logo.
- SIMATIC S7 CP** logo.
- A list of navigation options: "Start page", "Identification", "Diagnostics buffer", "Module information", "Industrial Ethernet", and "SEND/RECEIVE communication".

Right Sidebar: A vertical sidebar on the far right contains the following elements:

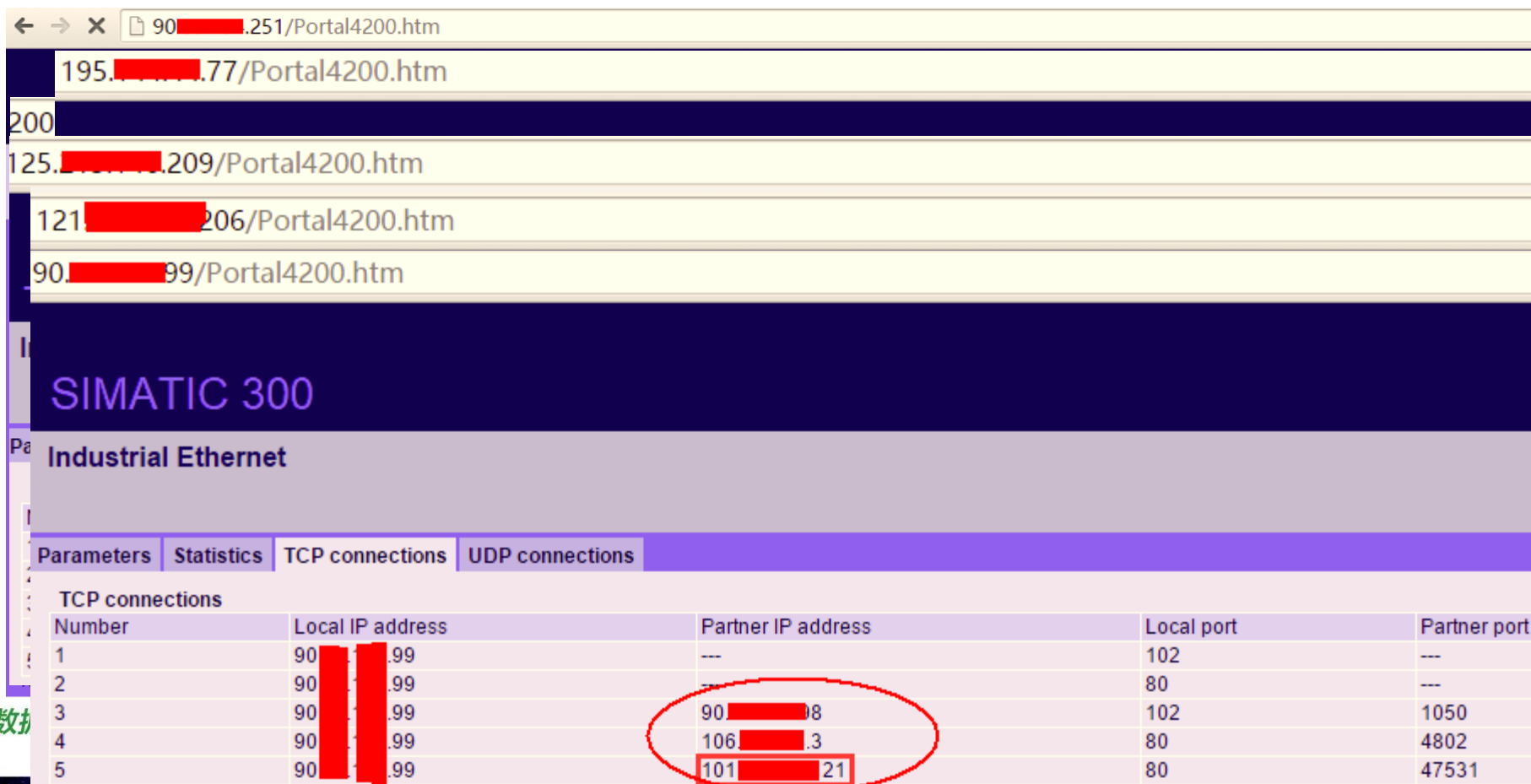
- English** button.
- Time: "05:29:19".
- Status** section with a list of connection states: "ESTABLISHED", "LISTEN", "LISTEN", "ESTABLISHED", "ESTABLISHED", "ESTABLISHED", "ESTABLISHED", "SYN RECEIVED", "ESTABLISHED", "SYN RECEIVED", "SYN RECEIVED".

Bottom Bar: The bottom of the interface includes a navigation bar with the following elements from left to right: "数据" (Data), "RTS Services", "Generic", "Generic", and "RTS SCADA Server".

枚举暗物质与对应的情报经验

工控威胁

- 也可以成为「蜜罐」捕捉对手痕迹



90.251/Portal4200.htm

195.77/Portal4200.htm

200

125.209/Portal4200.htm

121.206/Portal4200.htm

90.99/Portal4200.htm

SIMATIC 300

Industrial Ethernet

Parameters Statistics TCP connections UDP connections

TCP connections

Number	Local IP address	Partner IP address	Local port	Partner port
1	90.99	---	102	---
2	90.99	---	80	---
3	90.99	90.8	102	1050
4	90.99	106.3	80	4802
5	90.99	101.21	80	47531

枚举暗物质与对应的情报经验

工控威胁

- 思考个问题：你有全球某工控设备或工控网络的控制权，你能如何？
 - 拿工控网络尽可能全面的情报信息？
 - 潜伏？你敢搞破坏试试？
 - 同样，你思考的问题，地下黑客不仅早思考了还行动了...

枚举暗物质与对应的情报经验

物联网屠宰场 - 小结

- 全球这么多脆弱的物联网设备，你有何感想？
 - 像不像一个个屠宰场？菜市场？
 - 肆虐一遍全球的成本越来越低
 - 嵌入式木马技术的日臻成熟，蠕虫式感染传播
 - ZMap/MASSCAN的流行
 - 租用服务器与带宽是件很简单的事
 - 一个漏洞爆发，全球地下黑客都会第一时间/第二时间行动，甚至更早

枚举暗物质与对应的情报经验

物联网屠宰场 - 小结

- 全球这么多脆弱的物联网设备，你有何感想？
 - 我们该做什么？
 - 我们的应急响应呢？黄金应急时间呢？
 - 如何对抗这群地下黑客？
 - 我们必须像他们一样去思考，包括执行力！
 - 牢记：对抗是持续的！不是过了黄金时间就可以歇息，这种持续可能是N年...
 - 幻想着：这些物联网设备的升级（打补丁）是件非常容易的事

枚举暗物质与对应的情报经验

之心脏出血里的情报经验

枚举暗物质与对应的情报经验

心脏出血里的情报经验

- 2014/4/8全面爆发
- 我们用了6h完成第一轮全球应急，给出了影响面
- 我们持续监测全球修复趋势1周
- 我们得出结论：
 - 全球影响面至少2,433,550
 - 美国受影响遥遥领先，中国全球排名16
 - 3天的修补速率，新加坡第1，美国第2，而中国全球102垫底，才修复了18%
 - 从这样的情报里你能得出什么结论？

枚举暗物质与对应的情报经验

心脏出血里的情报经验

- 2015/4/8我们完成1周年回顾
- 结论如下：
 - 1年的时间，全球受影响IP数量仅为爆发时的14.6%
 - 协议依赖性明显，受影响IP中，HTTPS两次占比都超过50%
 - 西方发达国家修复效率高于发展中国家
 - 较大规模站点对安全更为重视，国内外知名大网站几乎未发现相关漏洞
 - 我国持续响应能力依然需要努力提高，虽然从最初的18%的修复率，上升到了59.9%，但还是垫底
 - 从这样的情报里你能得出什么结论？

枚举暗物质与对应的情报经验

心脏出血里的情报经验

- 1周年的绵羊墙

端口	全部	国家	全部	筛选数据
IP地址	端口	国家	时间	
1.0.131.153	443	 Thailand Loei	2015-04-7 10:33:47	
1.0.199.155	443	 Thailand	2015-04-7 10:33:47	
1.0.202.245	443	 Thailand Ranong	2015-04-7 10:33:47	
1.0.228.204	443	 Thailand Phuket	2015-04-7 10:33:47	
1.0.235.100	443	 Thailand Phuket	2015-04-7 10:33:47	
1.0.243.200	443	 Thailand Phuket	2015-04-7 10:33:47	
1.0.38.101	443	 China Guangzhou	2015-04-7 10:33:47	
1.0.38.103	443	 China Guangzhou	2015-04-7 10:33:47	
1.0.38.105	443	 China Guangzhou	2015-04-7 10:33:47	
1.0.38.106	443	 China Guangzhou	2015-04-7 10:33:47	
1.0.38.107	443	 China Guangzhou	2015-04-7 10:33:47	
1.0.38.110	443	 China Guangzhou	2015-04-7 10:33:47	
1.0.38.111	443	 China Guangzhou	2015-04-7 10:33:47	
1.0.38.112	443	 China Guangzhou	2015-04-7 10:33:47	
1.0.38.114	443	 China Guangzhou	2015-04-7 10:33:47	
1.0.38.115	443	 China Guangzhou	2015-04-7 10:33:47	

枚举暗物质与对应的情报经验

心脏出血里的情报经验

- 1周年的绵羊墙里的这些都是什么

```
3713 26589 1 <!> 통합로그인"  
3714 26590 1 <!> 원글리쉬폰"  
3715 26591 1 <!> 모바일 " "  
3716 26592 1 <!> 여주대학교 파일시스템 "  
3717 26592 1 <!> 여주대학교 파일시스템 "  
3718 26593 1 <!> 전남대학교 중앙도서관 "  
3719 26594 1 <!> 전북대학교 웹디스크 "  
3720 26595 1 <!> 경북대학교 물리학과 . "  
3721 26596 1 <!> 연제도서관 홈페이지 방문을 환영합니다 . "  
3722 26597 1 <!> 접속테스트 페이지 "  
3723 26598 1 <!> 천문연구원 웹하드 "  
3724 26599 1 <!> 란타임 에러 "  
3725 26600 1 <!> 리플코리아 포럼에 오신걸 환영합니다 . "  
3726 26601 1 <!> 일베저장소 - 일간베스트  
3727 26601 1 <!> 일베저장소 - 일간베스트  
3728 26602 1 <!> 덴더라이언 - 너에게 부는 바람 "  
3729 26603 1 <!> 유흥몬스터 - 유몬 - 강남오피,강북오피,오피,립카페,립다방,물다방-  
3730 ,건마,오피녀,룸녀,야사,야동,국산,백마"
```

枚举暗物质与对应的情报经验

心脏出血里的情报经验 - 小结

- 来个另类的小结吧
 - 谁都不是预言家，但是成为马后炮太容易:)
 - 比如：关于心脏出血应急响应的情报分析，有人说应该全球实时刷数据然后分析，并构建了各种高大上的方案
 - 很多时候：高大上 ~ = 扯淡

枚举暗物质与对应的情报经验

心脏出血里的情报经验 - 小结

- 来看看这个扯淡方案吧
 - $64K/S/IP * \text{全球}240w\text{受影响的IP} = 153600000K/S$
 - $= 153.6G/S$
 $153.6G/S * 24h = ?$
 - $= 13271040G/D$
 $= 13271T/D$
 $= 13.3P/D$
 - 每天要存储13.3P的数据
- 这种方案带来的情报分析工作是一件极其复杂的工程问题
- 等落实，黄花菜都凉了！

枚举暗物质与对应的情报经验

心脏出血里的情报经验 - 小结

- 我们的心得
 - 要知道中国全球应急能力排名102垫底
 - 这是一个极其复杂的战场，需要一个高敏锐度与高执行力的指挥官
 - 打硬战就得有打硬战的姿势
 - 时间就是一切
 - 但如果没之前的人与架构的储备，也没辙
 - 需要盟军！
 - XCERT、各类媒体、国家机关...
 - 我们的核心心得：粗暴美学

枚举暗物质与对应的情报经验

之NoSQL之殇

枚举暗物质与对应的情报经验

NoSQL之殇

- 那些主流的NoSQL
 - Redis、Memcached、MongoDB、ElasticSearch、...
 - 无认证或脆弱的认证机制或远程任意命令执行等漏洞...
 - 储备大量敏感数据

枚举暗物质与对应的情报经验

NoSQL之殇

The screenshot displays a web application security tool interface. At the top, there are input fields for 'port:11211' and 'port:6379', with a '探索一下' (Explore) button next to 'port:11211'. Below these, there is a search bar containing 'port:9200' and another '探索一下' button. The main results area shows a search for 'port:27017' yielding '找到约 78655 条结果 (0.104 秒)' (Found about 78655 results in 0.104 seconds). Below this, the IP address '41.204.221.238' is listed. Further down, a search for '41.203.21.' is shown, with results for 'Elasticsearch REST API:1.1.2' and 'name: cwa001; Lucene version: ...'. The results are associated with 'South Africa' and the date '九月 29, 2015'. On the right side, there is a '9200' label and an 'HTTP' label. The HTTP response details are shown: 'HTTP/1.0 200 OK', 'Content-Type: application/json; charset=UTF-8', and 'Content-Length: 295'. The JSON response body is displayed:

```
{
  "status" : 200,
  "name" : "cwa001",
  "version" : {
    "number" : "1.1.2",
    "build_hash" : "e511f7b28b77c4d99175905fac65bffb4c80cf7",
    "build_timestamp" : "2014-05-22T12:27:39Z"
  }
}
```

NoSQL之殇

- A screenshot of the Redis Desktop Manager application. The title bar says 'Redis Desktop Manager'. Below it, there's a tab labeled 'Redis Desktop Manager'. The main area shows a key-value pair. The key is '1007H[REDACTED]F21F' and the value is a JSON object. The value is displayed as 'Plain text'. The JSON object contains user information, including 'userinfo', 'uid', 'uuid', 'email', 'passwd', 'last_login_ip', 'platform', 'locked', 'flag_del', 'login_num', 'last_login', 'reg_time', 'reg_ip', 'sex', 'avatar', 'm', 's', 'v', 'true_name', 'mobile', 'nickname', 'rtype', 'loginaccount', 'logintype', 'phoneflag', 'create_time', and 'extdata'. The values are partially redacted with black boxes.

枚举暗物质与对应的情报经验

NoSQL之殇

- 比如：全球MongoDB的一组最新统计数据 - ZoomEye
 - 至少4.7万个MongoDB IP在网络空间里暴露
 - 无口令的至少有3.8万IP，其中6.7万个DB
 - 数据总量至少439TB
 - 特别注下：Shodan说将近600TB，实际上大家统计维度不同
 - Shodan(listDatabases->sizeOnDisk) vs ZoomEye(db.stats()->storageSize)
 - 严谨来说：ZoomEye的成果更为震撼

枚举暗物质与对应的情报经验

NoSQL之殇

- 再比如，只需做简单的分析就能发现很多亮点：
 - 色情站点，包含账号信息
 - 若干天涯论坛有关的账号信息
 - 日约交友站，包含账号信息
 - 在线游戏站点，包含账号信息
 - 提供在线预约车位服务的站点，包含账号信息
 - 包含「微信玩家奖励」等字符，最大表appUser.mail，行数685374
 - 包含手机用户的支付日志（手机型号、系统版本、IP、MAC、IMEI等）
 - 订餐App的数据库，其中包括账号信息
 - ...

枚举暗物质与对应的情报经验

NoSQL之殇 - 小结

- 这么多数据（秒PB），你有何感想？

[回忆]透视网络空间

真正的透视需要做到

- 组件识别
- 组件之间的层级关系，比如Web组件的8+1层结构
- 组件高一维度的设备信息
- 设备之间的网络层级关系
- 设备高一维度的使用方信息（人）
- 人高一维度的社交信息
- 物理位置信息
- 漏洞信息 - 开启上帝视角
- ...



枚举暗物质与对应的情报经验

NoSQL之殇 - 小结

- 这么多数据（秒PB），你有何感想？
 - 别问了！我只想静静！

枚举暗物质与对应的情报经验

之轻松一刻

枚举暗物质与对应的情报经验

得到CDN背后网站的真实IP

- 那些技巧
 - 子域名的IP如果不在CDN后面，那么C段一般可以发现目标域名的真实IP
 - 目标域名如果有发邮件功能，查看邮件的详情，可能可以发现真实IP
 - 如果目标网站有phpinfo这类的探针，也会暴露
 - 如果目标网站有相关漏洞可以执行系统命令或系统报错等，也有可能暴露真实IP
 - 善于Google，可能可以发现某些平台的历史记录里有真实IP
 - 善于whois反查目标域名，一般会发现同一个人注册的多个域名，相似域名有可能是一个IP上或一个C段
 - DDoS打过去，一般流量够大，CDN平台如果对目标域名做回源处理那么就会暴露真实IP

枚举暗物质与对应的情报经验

得到CDN背后网站的真实IP

- 一般真实IP会做302跳到对应的域名，所以在ZoomEye里搜相关域名，如"xxx.net"，就有可能发现真实IP

The screenshot shows a ZoomEye search interface. At the top, a search bar contains a redacted domain ".net" and a button labeled "探索一下". Below the search bar, it says "找到约 2 条结果 (0.152 秒)".

The first result shows an IP address "219. [redacted].46" with a tooltip that says "在新窗口打开". Below the IP, it lists "Microsoft IIS httpd:6.0" and "China Beijing". A date "七月 23, 2015" is circled in red. To the right, an "HTTP" status block shows a "302 Moved Temporarily" response, with the status code "302" circled in red. The response includes headers like "Date: Thu, 23 Jul 2015 03:19:18 GMT", "Server: Microsoft-IIS/6.0", and "location: http://[redacted].net/huiyuan".

The second result is identical in structure, showing the same IP "219. [redacted].46", "Microsoft IIS httpd:6.0", "China Beijing", and a date "三月 30, 2015" circled in red. The "HTTP" status block also shows a "302 Moved Temporarily" response, with the status code "302" circled in red. The headers are similar, with "Date: Mon, 30 Mar 2015 00:54:40 GMT" and "location: http://[redacted].net/huiyuan".

枚举暗物质与对应的情报经验

得到CDN背后网站的真实IP

- 这种技巧对于渗透测试来说是很需要的
- 为了真的做好用户网站安全，需要考虑这类情报的获取

枚举暗物质与对应的情报经验

说说Google IP

ZoomEy 探索一下

搜索结果 全球视角

搜索类型
公网设备
Web 服务

找到 16281 条结果 (0.041 秒)。

38.96.223.132

United States Dallas
九月 11, 2015

80 HTTP/1.0 200 OK
Date: Fri, 11 Sep 2015 00:08:36 GMT
Expires: -1
Cache-Control: private, max-age=0
Content-Type: text/html; charset=ISO-8859-1
Server: gws

answer.py country:Japan 探索一下

answer.py country:"United Kingdom" 探索一下

38.96.223.181

United States Dallas
九月 11, 2015

80 HTTP/1.0 200 OK
Date: Fri, 11 Sep 2015 00:08:35 GMT
Expires: -1
Cache-Control: private, max-age=0
Content-Type: text/html; charset=ISO-8859-1
P3P: CP="This is not a P3P policy! See http://www.google.com/support/accounts/bin/answer.py"

Service

Unknown	16159
http	122

Country

UNITED STATES	5934
MOUNTAIN VIEW	1571
SAN ANTONIO	416
MAPLEWOOD	197
DALLAS	165
ATLANTA	149
YERINGTON	147
VINELAND	143
GARY	140
MAMARONECK	140
SAN FRANCISCO	120

枚举暗物质与对应的情报经验

说说Google IP



← → ↻ 113. [REDACTED] 101/scholar?hl=zh-CN&q=i2p&btnG=&lr=

网页 图片 更多...

Go Google i2p

学术搜索 找到约 14,000 条结果 (用时0.04秒)

文章

小提示: 只搜索中文(简体)结果, 可在 学术搜索设置 指定搜索语言

我的图书馆

时间不限

2015以来

2014以来

2011以来

自定义范围...

按相关性排序

按日期排序

Privacy-implications of performance-based peer selection by onion-routers: a study using I2P

M Herrmann, C Grothoff - Privacy Enhancing Technologies, 2011 - Springer

Abstract I2P is one of the most widely used anonymizing Peer-to-Peer networks on the Internet today. Like Tor, it uses onion routing to build tunnels between peers as the basis for providing anonymous communication channels. Unlike Tor, I2P integrates a range of ...

被引用次数: 18 相关文章 所有 26 个版本 引用 保存

[PDF] I2p data communication system

B Zantout, R Haraty - ... of the tenth international conference on ..., 2011 - csm.beirut.lau.edu.lb

Abstract---As communication becomes more and more an integral part of our day to day lives, the need to access information increases as well. Security is currently one of the most important factors to consider in our aim to achieve ubiquitous computing, and with it raises ...

被引用次数: 18 相关文章 所有 2 个版本 引用 保存 更多

枚举暗物质与对应的情报经验

说说Google IP

- 为什么好好的提这个？
 - 墙已经是一个客观存在，无需避讳，且得正视
 - 在情报的游戏规则里，墙是个可以被突破的障碍

枚举暗物质与对应的情报经验

整体小结

- 网络空间就是一个超级大宝藏，有太多的「暗物质」等着我们去消除
 - 这次的分享仅仅是冰山一角
- 每分每秒都有地下黑客的动静
 - 随便部署一些蜜罐系统即可知道
- 我们的战场不应该只在我们的服务器集群里，应该在网络空间里

枚举暗物质与对应的情报经验

意犹未尽？让我们一起踏上征程吧！：)





中国互联网安全大会



360互联网安全中心

Q&A